WEB APPLICATION PENETRATION TEST — VULNERABILITY REPORT

Unrestricted File Upload — Weak Extension-Only Validation

Finding NVP-011 · **Medium**

Product: PHPGurukul News Portal Project in PHP and MySQL — V4.1

Assessment target: http://localhost/newsportal/newsportal/

Technology: Apache 2.4.58 · PHP 8.2.12 · MariaDB 10.4.32 (DB user: root)

Assessment date: 2026-10-31

Classification: CONFIDENTIAL — authorised lab assessment (review draft)

Document Control

Finding ID	NVP-011
Vulnerability	Unrestricted File Upload — Weak Extension-Only Validation
Severity	**Medium**
CVSS 4.0	5.4 `CVSS:4.0/AV:N/AC:L/AT:P/PR:L/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N`
CWE	CWE-434 (Unrestricted Upload); CWE-646
OWASP	A05:2021 Security Misconfiguration
CVE verification	No matching publicly assigned CVE was identified for this specific finding and product/version during the research performed.
Status	CONFIRMED (manually validated & re-verified)

1. Executive Summary

The image upload validates only the last four characters of the client filename and performs no content/MIME check. Validation is trivially weak, though the handler renames files to an image extension, which limits direct code execution.

2. Affected Target

Affected URL	/admin/add-post.php, /admin/change-image.php
Affected parameter	postimage (multipart file)
Affected role	Authenticated admin/sub-admin
Authentication	Login required

3. Technical Description

add-post.php takes $extension = last 4 chars of the filename and checks it against [".jpg","jpeg",".png",".gif"] with no getimagesize()/MIME check, then saves md5(name).$extension. Arbitrary file content is accepted under an image name; because the stored extension is forced to an image type, direct PHP execution is not achievable through this handler alone (honest limitation), but the control is ineffective and risky (stored HTML/SVG, content spoofing, and reliance on filename trust).

4. Root Cause Analysis

```
admin/add-post.php:21-36 — $extension=substr($imgfile,strlen($imgfile)-4);
if(!in_array($extension,$allowed)) reject; else
move_uploaded_file(...,"postimages/".md5($imgfile).$extension); // no content validation
```

5. Preconditions

An authenticated session with post/image creation rights.

6. Proof of Concept — Step-by-Step Reproduction

1. Authenticate and submit Add Post with an uploaded file whose name ends in .jpg but whose bytes are arbitrary (not a real image).
2. The server accepts it (no content/MIME validation) and stores it under postimages/.
3. Demonstrated functionally during NVP-006 (a non-image byte sequence named .jpg was accepted).

7. HTTP Request Evidence

```
POST /newsportal/newsportal/admin/add-post.php (multipart/form-data) with
postimage="vapt_test.jpg" containing non-image bytes.
```

8. HTTP Response Evidence

```
File stored as admin/postimages/<md5>.jpg (content never validated).
```

9. Proof of Concept — Visual Evidence

> **Evidence note:** Confirmed from source and functionally during post creation; RCE not achieved due to forced image extension (stated honestly rather than overclaimed).

10. Actual Security Impact

Weak upload control allowing storage of arbitrary content under image names; raises risk of content spoofing/stored markup and would become code execution under any server misconfiguration or secondary include flaw.

Exploitation complexity	Low for any authenticated user.
Realistic attack scenario	An authenticated user uploads disguised content; combined with a server misconfig or LFI it could escalate.

11. Remediation Recommendations

Validate real content (getimagesize/finfo MIME), re-encode images, use a server-generated random name with a safe extension, store outside the web root or disable script execution in the upload directory.

Secure code example

```
$info = getimagesize($_FILES['postimage']['tmp_name']);
if ($info===false || !in_array($info['mime'],['image/jpeg','image/png','image/gif'])) reject();
```

12. Retesting Procedure

Upload a non-image named .jpg; a fixed system rejects it on content validation.

13. References

- CWE-434
- OWASP WSTG-BUSL-09
- OWASP A05:2021

14. Conclusion

Confirmed weak upload validation (content unchecked). RCE not demonstrated due to extension rename — reported accurately as Medium.